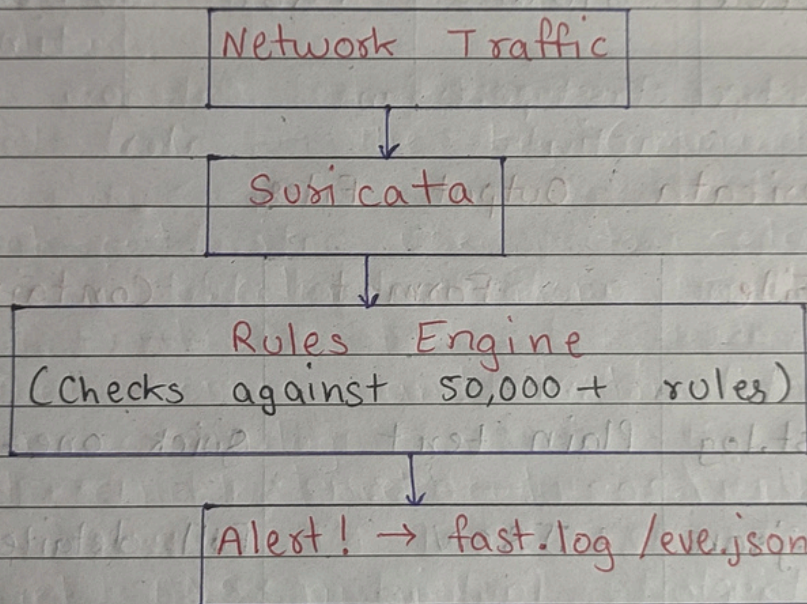


Day: 18

* What is Suricata?

- Suricata is a Network Intrusion Detection System (NIDS) — it monitors network traffic in real time and automatically generates alerts when it sees suspicious activity matching known attack patterns (signatures / rules).



* Suricata vs Zeek vs Wireshark

Feature	Wireshark	Zeek	Suricata
Primary use	Manual inspection	Log generation	Automated alerting
Output	Raw packets	Structured logs	Alerts + logs

Detects threats?	No (you do)	No (you do)	Yes (automatic)
Rule-based?	No	No	Yes
Used by	Everyone	Enterprise SOC	Enterprise SOC
Speed	Slow	Fast	Real-time

* Suricata Output Files

File	Format	Contains
fast.log	Plain text	Quick one-line alerts
eve.json	JSON	Full detailed alerts
stats.log	Plain text	Performance statistics
http.log	Plain text	HTTP requests seen
dns.log	Plain text	DNS queries seen

* Suricata Rule Structure

- Every Suricata rule has this structure:

action proto src_ip src_port
direction dst_ip dst_port
(options)

• Example :

alert tcp any any → any 4444
(msg: "Possible Metasploit C2",
sid : 1000001; rev: 1;)

* Rule Actions

alert → Generate an alert

drop → Drop the packet (IPS mode)

reject → Reject and send RST

pass → Allow and stop processing

* Rule Options — The Important Ones

Option	Example	Meaning
msg	msg: "Malware detected"	Alert message
sid	sid : 1000001	Unique rule ID
rev	rev : 1	Rule version
content	content: "gate.php"	Match string in packet

nocase	nocase	case insensitive match
pcr	pcr: "/evil.exe/i"	Regex match
flow	flow: established	Match established connections
threshold	threshold: 5,60	Alert after 5 hits in 60 seconds
classtype	classtype: trojan-activity	Category of alert

* Reading a Suricata Alert

• Fast.log.format:

```
01/14/2024 - 03:42:17 [**]
[1:2001219:20] ET MALWARE Possible
Metasploit Payload [**]
[Classification: A Network Trojan was
detected] [Priority: 1]
{TCP} 192.168.1.50:49832 ->
185.220.X.X:4444
```

• Breaking it down:

```
01/14/2024 - 03:42:17 → Timestamp
[1:2001219:20] → [gid:sid:rev]
(From rule msg field)
Priority: 1 → Severity
(1 = high, 3 = low)
```

{ TCP 3 → Protocol
 192.168.1.50 : 49832 → Source
 IP: port
 185.220.x.x : 4444 → Destination
 IP: port

* eve.json — The Full Alert

- Eve.json gives much more detail:

```
{
  "timestamp": "2024-01-14T03:42:17",
  "event_type": "alert",
  "src_ip": "192.168.1.50",
  "src_port": 49832,
  "dest_ip": "185.220.x.x",
  "dest_port": 4444,
  "proto": "TCP",
  "alert": {
    "action": "allowed",
    "gid": 1,
    "signature_id": 2001219,
    "rev": 20,
    "signature": "ET MALWARE: Possible  

    Metasploit Payload",
    "category": "A Network Trojan was  

    detected",
    "severity": 1
  }
}
```

* Writing Your Own Rules

- Rule 1 — Detect Metasploit C2:

```

alert tcp any any -> any 4444
Cmsg: "Possible Metasploit C2 Port 4444";
sid: 1000001; rev: 1;)

```

- Rule 2 — Detect suspicious User-Agent:

```

alert http any any -> any any
Cmsg: "Suspicious Empty User-Agent";
http.user-agent; content: "";
sid: 1000002; rev: 1;)

```

- Rule 3 — Detect gate.php C2 URL:

```

alert http any any -> any any
Cmsg: "Possible C2 gate.php";
http.uri; content: "gate.php";
nocase; sid: 1000003; rev: 1;)

```

- Rule 4 — Detect DNS to .ru TLD:

```

alert dns any any -> any any
Cmsg: "DNS query to .ru domain";
dns.query; content: ".ru"; nocase;
sid: 1000004; rev: 1;)

```

* Suricata Rule Sets

- You don't write all rules manually — Suricata uses rulesets from:

1) Emerging Threats (ET) Open → Free

2) ET Pro → Paid

3) Snort Community → Good (Free)

4) PT Research → Good (Free)

Note: ET Open has 40,000+ rules covering almost every known malware family.

* DFIR Use of Suricata

• In a real investigation you would:

1) Load the PCAP into Suricata offline

2) Read the `eve.json` alerts

3) Pivot on the alerted IPs in Wireshark for deeper inspection

4) Cross-reference with Zeek logs for full content